เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 7: Session Security และ Login Protection

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถสร้าง Session ID ใหม่หลัง Login ด้วย session_regenerate_id() ได้อย่างเหมาะสม
2. เพื่อให้นักศึกษาสามารถกำหนดและทดสอบ Idle Timeout และ Absolute Timeout สำหรับ Session ได้
3. เพื่อให้นักศึกษาสามารถตั้งค่า Session Cookie ได้แก่ HttpOnly, Secure และ SameSite ได้
4. เพื่อให้นักศึกษาสามารถพัฒนากลไกจำกัดจำนวนครั้งในการ Login และระงับการ Login ชั่วคราวได้
5. เพื่อให้นักศึกษาสามารถตรวจจับการเปลี่ยนแปลงของ User-Agent และทำ Logout อย่างปลอดภัยได้

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab07_รหัสนักศึกษา(มีขีด).pdfแ
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★

โจทย์ที่กำหนด

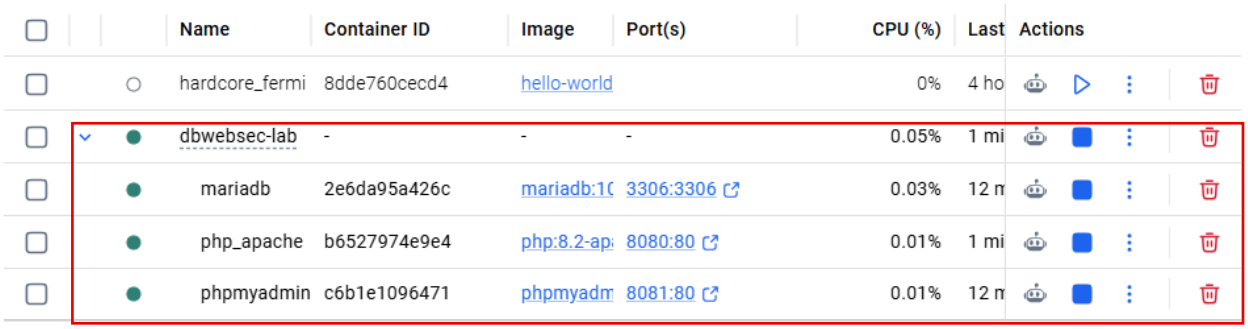
งานปฏิบัติการนี้ให้ให้นักศึกษานำระบบ Login/Logout จาก Lab06 มาปรับปรุงให้มีความปลอดภัยมากขึ้น โดยเน้นการป้องกัน Session Fixation การลดความเสี่ยงจาก Session Hijacking การกำหนดเวลาหมดอายุของ Session การตั้งค่า Cookie Security Flags การจำกัดจำนวนครั้งในการเข้าสู่ระบบ การตรวจจับการเปลี่ยนแปลงของ User-Agent และการทำ Logout อย่างปลอดภัย ระบบยังคงใช้หน้า Lab07_profile.php เป็นหน้าที่เข้าถึงได้เฉพาะผู้ใช้ที่ Login แล้ว

ลำดับการทำงานของระบบ

1. เปิด Lab07_login.php และตรวจสอบ Session ID ก่อน Login
2. กรอก Username และ Password แล้วส่งไปยัง Lab07_login_process.php
3. ระบบตรวจสอบจำนวนครั้งที่ Login ผิดในช่วง 5 นาที
4. เมื่อรหัสผ่านถูกต้อง ระบบสร้าง Session ID ใหม่และบันทึกเวลาการ Login, เวลาที่ใช้งานล่าสุด และ User-Agent
5. เข้าสู่ Lab07_profile.php ซึ่งจะตรวจสอบสถานะ Login, Session Timeout และ User-Agent
6. เมื่อไม่ใช้งานเกินเวลาที่กำหนด หรือ User-Agent เปลี่ยน ระบบจะยกเลิก Session และกลับหน้า Login
7. เมื่อกด Logout ระบบจะล้างข้อมูล Session ลบ Session Cookie และทำลาย Session

โดยมีขั้นตอนการสร้าง ดังนี้

1. เปิด docker ที่เคยสร้างไว้ และ Start project dbwebsec-lab ซึ่งประกอบด้วย containers mariadb, php_apache และ phpmyadmin



2. ให้ใช้ฐานข้อมูล db_lab06 และตารางผู้ใช้(users) ที่สร้างไว้แล้วใน Lab06 (หากยังไม่ได้สร้างให้ดูคำสั่งใน Lab06) และให้สร้างตารางเพิ่มอีก 1 ตาราง คือ ตาราง login_attempts โดยมีโครงสร้าง ของ ดังนี้

Field	Data Type	ข้อกำหนด	ความหมาย
id	INT	PRIMARY KEY, AUTO_INCREMENT	รหัสรายการ
username	VARCHAR(50)	NOT NULL	ชื่อผู้ใช้ที่ใช้ Login
ip_address	VARCHAR(45)	NOT NULL	IP Address ของผู้ร้องขอ
attempted_at	DATETIME	DEFAULT CURRENT_TIMESTAMP	วันและเวลาที่ทดลอง Login
success	TINYINT(1)	DEFAULT 0	0 = ไม่สำเร็จ, 1 = สำเร็จ

ตัวอย่างคำสั่ง SQL ในการสร้างตาราง login_attempts

```
CREATE TABLE IF NOT EXISTS login_attempts (
    id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NOT NULL,
    ip_address VARCHAR(45) NOT NULL,
    attempted_at DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
    success TINYINT(1) NOT NULL DEFAULT 0,
    INDEX idx_login_attempts_username_time (username, attempted_at)
);
```

3. ให้นักศึกษาสร้างโฟลเดอร์ Lab07 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 6 ไฟล์ มีรายละเอียด ดังนี้

1. Lab07_config.php สำหรับเชื่อมต่อฐานข้อมูล ตั้งค่า Session Cookie และเก็บฟังก์ชันที่ใช้ซ้ำ
2. Lab07_login.php สำหรับแสดงแบบฟอร์ม Login และข้อความสถานะต่าง ๆ
3. Lab07_login_process.php สำหรับตรวจสอบ Login จำกัดจำนวนครั้ง และสร้าง Session
4. Lab07_auth_check.php สำหรับตรวจสอบสิทธิ์ Session Timeout และ User-Agent
5. Lab07_profile.php สำหรับหน้าข้อมูลผู้ใช้ที่ต้อง Login
6. Lab07_logout.php สำหรับ ล้าง Session และ Cookie อย่างปลอดภัย

3.1 ให้สร้างไฟล์ชื่อ Lab07_config.php เพื่อเก็บค่ากำหนดของระบบและฟังก์ชันที่ใช้ซ้ำ โดยไฟล์นี้ใช้เชื่อมต่อฐานข้อมูล ตั้งค่า Session Cookie ก่อน session_start() กำหนดเวลา Timeout และเก็บฟังก์ชันที่ใช้ซ้ำคำสั่งของ ไฟล์ Lab06_config.php มีดังนี้

```php
<?php
declare(strict_types=1);
date_default_timezone_set('Asia/Bangkok');

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab06';
const DB_USER = 'root';
const DB_PASS = 'root';

const IDLE_TIMEOUT = 60;
const ABSOLUTE_TIMEOUT = 300;
const MAX_LOGIN_ATTEMPTS = 5;
const LOGIN_WINDOW_MINUTES = 5;

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

$isHttps = isset($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off';

session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => '',
    'secure' => $isHttps,
    'httponly' => true,
    'samesite' => 'Lax'
]);

session_start();
```

```php
try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
}

function h(?string $value): string
{
    return htmlspecialchars(
        $value ?? '',
        ENT_QUOTES | ENT_SUBSTITUTE,
        'UTF-8'
    );
}

function destroy_session_safely(): void
{
    $_SESSION = [];

    if (ini_get('session.use_cookies')) {
        $params = session_get_cookie_params();

        setcookie(
            session_name(),
            '',
            [
                'expires' => time() - 42000,
                'path' => $params['path'],
                'domain' => $params['domain'],
                'secure' => $params['secure'],
                'httponly' => $params['httponly'],
                'samesite' => $params['samesite'] ?? 'Lax'
            ]
        );
    }

    session_destroy();
}
```

3.2 สร้างไฟล์ Lab07_login.php ไฟล์นี้เป็นหน้า Login ต้องแสดงข้อความกรณี Login ผิด ถูกระงับ Session หมดอายุ User-Agent เปลี่ยน และ Logout สำเร็จ รวมถึงแสดง Session ID ชั่วคราวเพื่อใช้ทดลองก่อน Login

```php
<?php
declare(strict_types=1);

require_once 'Lab07_config.php';

if (isset($_SESSION['user_id'])) {
    header('Location: Lab07_profile.php');
    exit;
}

$error = $_GET['error'] ?? '';
$message = $_GET['message'] ?? '';
?>
```

```html
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <title>Secure Login</title>
    <style>
        body { font-family: Arial, sans-serif; background: #f3f6f9; }
        .card { width: min(460px, 92%); margin: 60px auto; padding: 30px;
                background: #fff; border-radius: 12px; }
        .group { margin-bottom: 18px; }
        label { display: block; margin-bottom: 7px; font-weight: bold; }
        input { width: 100%; padding: 11px; box-sizing: border-box; }
        button { width: 100%; padding: 11px; border: 0; border-radius: 8px;
                 background: #0d6efd; color: #fff; cursor: pointer; }
        .error { margin-bottom: 18px; padding: 12px;
                 background: #f8d7da; color: #842029; }
        .success { margin-bottom: 18px; padding: 12px;
                   background: #d1e7dd; color: #0f5132; }
        .debug { margin-top: 18px; padding: 10px; background: #fff3cd;
                 word-break: break-all; }
    </style>
</head>
```

```
37  <body>
38  <div class="card">
39      <h1>Secure Login</h1>
40
41      <?php if ($error === 'invalid'): ?>
42          <div class="error">Invalid username or password.</div>
43      <?php elseif ($error === 'empty'): ?>
44          <div class="error">Username and password are required.</div>
45      <?php elseif ($error === 'locked'): ?>
46          <div class="error">Too many failed login attempts. Please try again later.</div>
47      <?php elseif ($error === 'idle_timeout'): ?>
48          <div class="error">Session expired because of inactivity. Please login again.</div>
49      <?php elseif ($error === 'absolute_timeout'): ?>
50          <div class="error">Maximum session time expired. Please login again.</div>
51      <?php elseif ($error === 'session_changed'): ?>
52          <div class="error">Browser information changed. Please login again.</div>
53      <?php endif; ?>
54
55      <?php if ($message === 'logout'): ?>
56          <div class="success">Logout successful.</div>
57      <?php endif; ?>
58
59        <form action="Lab07_login_process.php" method="post">
60            <div class="group">
61                <label for="username">Username</label>
62                <input type="text" id="username" name="username"
63                       maxlength="50" autocomplete="username" required>
64            </div>
65
66            <div class="group">
67                <label for="password">Password</label>
68                <input type="password" id="password" name="password"
69                       autocomplete="current-password" required>
70            </div>
71
72            <button type="submit">Login</button>
73        </form>
74
75        <div class="debug">
76            Session ID before Login: <?= h(session_id()) ?>
77        </div>
78  </div>
79  </body>
80  </html>
```

3.3 สร้างไฟล์ Lab07_login_process.php โดยไฟล์นี้ตรวจสอบ Request Method รับข้อมูล Login ตรวจจำนวนครั้งที่ Login ผิด ตรวจรหัสผ่าน สร้าง Session ID ใหม่ และบันทึกข้อมูล Session Security

```php
<?php
declare(strict_types=1);

require_once 'Lab07_config.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: Lab07_login.php');
    exit;
}

$username = trim($_POST['username'] ?? '');
$password = $_POST['password'] ?? '';
$ipAddress = $_SERVER['REMOTE_ADDR'] ?? 'unknown';

if ($username === '' || $password === '') {
    header('Location: Lab07_login.php?error=empty');
    exit;
}

$windowMinutes = LOGIN_WINDOW_MINUTES;

$countSql = "
    SELECT COUNT(*) AS failed_count
    FROM login_attempts
    WHERE username = ?
      AND success = 0
      AND attempted_at >= DATE_SUB(NOW(), INTERVAL ? MINUTE)
";

$countStmt = $conn->prepare($countSql);
$countStmt->bind_param('si', $username, $windowMinutes);
$countStmt->execute();

$countResult = $countStmt->get_result()->fetch_assoc();
$failedCount = (int) ($countResult['failed_count'] ?? 0);
$countStmt->close();

if ($failedCount >= MAX_LOGIN_ATTEMPTS) {
    header('Location: Lab07_login.php?error=locked');
    exit;
}

```

```php
$sql = "
    SELECT id, fullname, username, password_hash, role
    FROM users
    WHERE username = ?
";

$stmt = $conn->prepare($sql);
$stmt->bind_param('s', $username);
$stmt->execute();
$user = $stmt->get_result()->fetch_assoc();
$stmt->close();

$loginSuccess =
    $user !== null &&
    password_verify($password, $user['password_hash']);

$successValue = $loginSuccess ? 1 : 0;

$logSql = "
    INSERT INTO login_attempts
        (username, ip_address, success)
    VALUES (?, ?, ?)
";

$logStmt = $conn->prepare($logSql);
$logStmt->bind_param('ssi', $username, $ipAddress, $successValue);
$logStmt->execute();
$logStmt->close();

if (!$loginSuccess) {
    header('Location: Lab07_login.php?error=invalid');
    exit;
}

session_regenerate_id(true);

$_SESSION['user_id'] = (int) $user['id'];
$_SESSION['fullname'] = $user['fullname'];
$_SESSION['username'] = $user['username'];
$_SESSION['role'] = $user['role'];
$_SESSION['login_time'] = time();
$_SESSION['last_activity'] = time();
$_SESSION['user_agent'] = $_SERVER['HTTP_USER_AGENT'] ?? '';
$_SESSION['login_ip'] = $ipAddress;

```

```
88   $deleteSql = "
89       DELETE FROM login_attempts
90       WHERE username = ?
91         AND success = 0
92   ";
93
94   $deleteStmt = $conn->prepare($deleteSql);
95   $deleteStmt->bind_param('s', $username);
96   $deleteStmt->execute();
97   $deleteStmt->close();
98
99   header('Location: Lab07_profile.php');
100  exit;
```

3.4 สร้างไฟล์ Lab07_auth_check.php ไฟล์นี้ตรวจสอบว่า Login แล้วหรือไม่ ตรวจ Idle Timeout, Absolute Timeout และตรวจการเปลี่ยนแปลงของ User-Agent ก่อนอนุญาตให้เข้าหน้า Profile

```
1   <?php
2   declare(strict_types=1);
3   require_once 'Lab07_config.php';
4
5   header('Cache-Control: no-store, no-cache, must-revalidate');
6   header('Pragma: no-cache');
7
8   if (!isset($_SESSION['user_id'])) {
9       header('Location: Lab07_login.php');
10      exit;
11  }
12
13  $currentTime = time();
14
15  if (
16      isset($_SESSION['last_activity']) &&
17      ($currentTime - (int) $_SESSION['last_activity']) > IDLE_TIMEOUT
18  ) {
19      destroy_session_safely();
20      header('Location: Lab07_login.php?error=idle_timeout');
21      exit;
22  }
23
24  if (
25      isset($_SESSION['login_time']) &&
26      ($currentTime - (int) $_SESSION['login_time']) > ABSOLUTE_TIMEOUT
27  ) {
28      destroy_session_safely();
29      header('Location: Lab07_login.php?error=absolute_timeout');
30      exit;
31  }
32
```

```php
$currentUserAgent = $_SERVER['HTTP_USER_AGENT'] ?? '';
$storedUserAgent = $_SESSION['user_agent'] ?? '';

if (!hash_equals($storedUserAgent, $currentUserAgent)) {
    destroy_session_safely();
    header('Location: Lab07_login.php?error=session_changed');
    exit;
}

$currentIp = $_SERVER['REMOTE_ADDR'] ?? 'unknown';

if (
    isset($_SESSION['login_ip']) &&
    $_SESSION['login_ip'] !== $currentIp
) {
    error_log(
        'Session IP changed for user ID: ' .
        (string) $_SESSION['user_id']
    );
}

$_SESSION['last_activity'] = $currentTime;
```

3.5 สร้างไฟล์ Lab07_profile.php

```php
<?php
declare(strict_types=1);

require_once 'Lab07_auth_check.php';
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <title>User Profile</title>
    <style>
        body { font-family: Arial, sans-serif; background: #f3f6f9; }
        .card { width: min(650px, 92%); margin: 60px auto; padding: 30px;
                background: #fff; border-radius: 12px; }
        .row { padding: 12px 0; border-bottom: 1px solid #e5e7eb; }
        .label { display: inline-block; min-width: 150px; font-weight: bold; }
        .logout { display: inline-block; margin-top: 24px; padding: 10px 18px;
                  background: #dc3545; color: #fff; text-decoration: none;
                  border-radius: 8px; font-weight: bold; }
        .debug { margin-top: 20px; padding: 12px; background: #fff3cd;
                 word-break: break-all; }
    </style>
</head>
```

```
<body>
<div class="card">
    <h1>User Profile</h1>

    <div class="row">
        <span class="label">Full Name:</span>
        <?= h($_SESSION['fullname'] ?? '') ?>
    </div>

    <div class="row">
        <span class="label">Username:</span>
        <?= h($_SESSION['username'] ?? '') ?>
    </div>

    <div class="row">
        <span class="label">Role:</span>
        <?= h($_SESSION['role'] ?? '') ?>
    </div>

    <div class="row">
        <span class="label">Login Time:</span>
        <?= date('H:i:s', (int) $_SESSION['login_time']) ?>
    </div>

    <div class="row">
        <span class="label">Last Activity:</span>
        <?= date('H:i:s', (int) $_SESSION['last_activity']) ?>
    </div>

    <div class="debug">
        Session ID after Login: <?= h(session_id()) ?>
    </div>

    <a class="logout" href="Lab07_logout.php">Logout</a>
</div>
</body>
</html>
```

3.6 สร้างไฟล์ Lab07_logout.php

```
<?php
declare(strict_types=1);

require_once 'Lab07_config.php';

destroy_session_safely();

header('Location: Lab07_login.php?message=logout');
exit;
```

งาน Capture ผลลัพธ์

งานที่ 1 การทดสอบความปลอดภัยของ Session

งานที่ 1.1 ตรวจสอบ Session ID ก่อนและหลัง Login

1. ให้เปิด Browser และกรอก URL http://localhost:8080/Lab07/Lab07_login.php
2. Capture หน้าจอที่แสดงค่า **Session ID before Login**
3. Login ด้วยข้อมูลที่ถูกต้อง

   Username: admin

   Password: Admin1234
4. เมื่อ Login สำเร็จ ระบบจะแสดงหน้า Lab07_profile.php
5. Capture หน้าจอที่แสดงค่า **Session ID after Login** จากนั้นเปรียบเทียบค่า Session ID ก่อนและหลัง Login

งานที่ 1.2 ตรวจสอบ Cookie Security Flags

1. Login เข้าสู่ระบบให้สำเร็จ
2. เปิด **Developer Tools** ของ Browser
3. เลือก Application ⟶ Cookies ⟶ http://localhost:8080
4. ตรวจสอบ Cookie ชื่อ PHPSESSID
5. Capture หน้าจอที่แสดงค่า
   - HttpOnly
   - Secure
   - SameSite
   - Path

งานที่ 1.3 ทดสอบ Idle Timeout

1. Login เข้าสู่ระบบให้สำเร็จและอยู่ที่หน้า Lab07_profile.php
2. ไม่ Refresh และไม่ใช้งานระบบเป็นเวลาเกิน **60 วินาที**
3. เมื่อครบเวลา ให้ Refresh หน้า Lab07_profile.php
4. Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 1.4 ทดสอบ Absolute Timeout

1. แก้ไขค่าใน Lab07_config.php ชั่วคราวเป็น const ABSOLUTE_TIMEOUT = 120;
2. Login เข้าสู่ระบบให้สำเร็จ
3. Refresh หน้า Lab07_profile.php ทุกประมาณ 20–30 วินาที เพื่อไม่ให้เกิด Idle Timeout
4. ใช้งานต่อเนื่องจนเวลาหลัง Login เกิน **120 วินาที**
5. Refresh หน้าอีกครั้งและ Capture ผลลัพธ์

งานที่ 2 การทดสอบการป้องกันการ Login

งานที่ 2.1 ทดสอบ Login Attempt Limiting

1. เปิด http://localhost:8080/Lab07/Lab07_login.php
2. ทดลอง Login ด้วย

   Username: admin

   และกรอก Password ที่ไม่ถูกต้อง เช่น **Password:** Admin123
3. ทำ Login ผิดให้ครบ **5 ครั้งภายใน 5 นาที**
4. ในครั้งที่ 6 ให้กรอกข้อมูลที่ถูกต้อง

   Username: admin

   Password: Admin1234
5. Capture หน้าจอผลลัพธ์ที่แสดง
6. เปิด phpMyAdmin และตรวจสอบข้อมูลในตาราง login_attempts
7. Capture หน้าจอตาราง login_attempts

งานที่ 2.2 ทดสอบการ Login หลังพ้นช่วงเวลาระงับ

เพื่อไม่ให้ใช้เวลารอนาน สามารถแก้ไขค่าใน Lab07_config.php ชั่วคราวเป็น

const LOGIN_WINDOW_MINUTES = 1;

จากนั้นดำเนินการดังนี้

1. Login ผิดจนครบจำนวนครั้งที่กำหนด
2. ตรวจสอบว่าระบบไม่อนุญาตให้ Login
3. รอให้พ้นช่วงเวลาที่กำหนด
4. Login ใหม่ด้วยข้อมูลที่ถูกต้อง

   Username: admin

   Password: Admin1234
5. Capture หน้า Lab07_profile.php

6. เปิด phpMyAdmin และตรวจสอบตาราง login_attempts จากนั้น Capture

งานที่ 3 การทดสอบ Secure Logout และ Cache Control

งานที่ 3.1 ทดสอบ Secure Logout ด้วยหลาย Tab

1. Login เข้าสู่ระบบให้สำเร็จ
2. เปิดหน้า http://localhost:8080/Lab07/Lab07_profile.php จำนวน **2 Tab**
3. ที่ Tab แรก ให้กดปุ่ม **Logout**
4. ตรวจสอบว่าระบบกลับไปหน้า Lab07_login.php
5. กลับไปยัง Tab ที่สอง
6. กด Refresh
7. Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 3.2 ทดสอบ Cache Control หลัง Logout

1. Login เข้าสู่ระบบและเปิดหน้า Lab07_profile.php
2. กดปุ่ม Logout
3. หลังจากกลับไปหน้า Login ให้กดปุ่ม **Back** ของ Browser
4. Capture หน้าจอผลลัพธ์ที่แสดง

